

ACTIVIDAD 01

ANÁLISIS Y PLANIFICACIÓN DEL PENTEST

Caso práctico: Aurora Market

Belinda Zamora Robles
Hacker Women Council · Ethical Hacking
4 de septiembre de 2026

Documento técnico de evaluación autorizada y controlada de seguridad para una plataforma de comercio electrónico.

1. Objetivo del pentest

- Identificar y validar, de forma controlada, vulnerabilidades técnicas y fallas de configuración en la aplicación web de Aurora Market.
- Estimar el riesgo real para la confidencialidad, integridad y disponibilidad de la información de clientes y de la operación comercial.
- Entregar recomendaciones priorizadas y reproducibles que permitan reducir la exposición antes de la nueva campaña publicitaria.

2. Alcance

SÍ SE EVALUARÁ	FUERA DEL ALCANCE
• Aplicación web pública de Aurora Market. • Autenticación y gestión de sesiones. • Catálogo, búsqueda, carrito y flujo de compra hasta antes del pago. • Formularios y validación de entradas. • Controles de acceso entre tipos de usuario. • Exposición de información y configuraciones visibles. • Integración con la base de datos únicamente desde la aplicación web autorizada.	• Módulo y pasarela de pagos. • Equipos personales o corporativos de empleados. • Correos, mensajería y cuentas personales. • Proveedores, redes o servicios externos no controlados por Aurora Market. • Ingeniería social, phishing y pruebas físicas. • Denegación de servicio, carga o acciones destructivas. • Modificación o extracción de datos reales de clientes.

3. Autorización y condiciones

- Contar con autorización escrita del propietario, contactos de emergencia y reglas de compromiso firmadas antes de iniciar.
- Trabajar en horarios de menor actividad, con ventana definida y aviso previo a las áreas técnicas y de negocio.
- Usar cuentas y datos de prueba; aplicar límites de solicitudes; detenerse ante inestabilidad, exposición de datos reales o impacto no previsto.
- Solicitar autorización adicional para cualquier acción con riesgo operativo y mantener registro de evidencias, tiempos y responsables.
- Tratar toda evidencia como confidencial, almacenarla cifrada, limitar su acceso y acordar su eliminación segura al cierre.

4. Tipo de pentest

Elección: Gray Box (caja gris). El equipo conoce que existen una aplicación web, una base de datos, mecanismos de autenticación y distintos tipos de usuario, pero no recibe el código fuente ni todos los detalles de arquitectura o tecnología. Esta información parcial, junto con credenciales de prueba, permite simular a un usuario con acceso limitado y profundizar sin asumir conocimiento interno completo. Black Box sería menos eficiente para el tiempo disponible; White Box no corresponde porque no se cuenta con toda la documentación ni el código.

JUSTIFICACIÓN

Equilibra realismo y cobertura: permite probar controles de acceso y rutas autenticadas, reduce tiempo de descubrimiento y conserva la perspectiva de un atacante con información limitada.

5. Planificación

Objetivos	Detectar vulnerabilidades, validar su impacto de manera segura y priorizar remediaciones antes de la campaña.
Alcance	Aplicación web y funciones autorizadas; exclusiones expresas de pagos, terceros, empleados, datos reales y disponibilidad.
Permisos y condiciones	Carta de autorización, reglas de compromiso, cuentas de prueba, ventanas de trabajo, límites técnicos y criterio de detención.
Metodología	PTES para el ciclo completo y OWASP WSTG para las pruebas específicas de la aplicación web.
Recopilación previa	URL y dominios autorizados, ambientes, roles, cuentas de prueba, arquitectura disponible, contactos y respaldos.
Recursos	Líder del pentest, analista web, responsable técnico de Aurora Market, navegador/proxy de pruebas, bitácora y repositorio cifrado.
Programación	Preparación: 1 día. Evaluación: 3 días en horario de baja actividad. Análisis y reporte: 2 días. Reprueba: 1 día.

6. Fases del pentest

1. Reconocimiento	Confirmar activos autorizados y recopilar únicamente información pública y técnica necesaria: tecnologías visibles, rutas, funciones, roles y superficie de ataque. No ampliar el alcance a dominios o proveedores no autorizados.
2. Análisis de vulnerabilidades	Revisar configuración, autenticación, sesiones, autorización, validación de entradas, manejo de errores, exposición de información y lógica de negocio. Correlacionar resultados automáticos con validación manual para reducir falsos positivos.
3. Explotación controlada	Validar solo los hallazgos necesarios con cuentas y datos de prueba, usando el impacto mínimo. No persistir, no alterar datos reales, no ejecutar denegación de servicio y detenerse si aparece información sensible o degradación.
4. Post-explotación	Determinar, sin expandir el acceso, qué activos o datos podrían verse afectados y documentar la ruta de impacto. Eliminar artefactos de prueba y confirmar con el responsable que el entorno quede estable.
5. Informe	Entregar resumen ejecutivo y detalle técnico por hallazgo: evidencia, activo, condición, impacto, probabilidad, severidad, recomendación y referencia. Priorizar acciones y realizar una reprueba para verificar correcciones.

Criterio transversal

Cada fase debe respetar alcance, legalidad, mínima intrusión, trazabilidad, confidencialidad y comunicación inmediata de incidentes críticos. La explotación no es un fin: solo se utiliza para demostrar riesgo de forma segura.

7. Investigación: metodología seleccionada

Se consultaron dos referencias reconocidas y complementarias:

PTES (Penetration Testing Execution Standard). Estructura el trabajo desde las interacciones previas y la recopilación de información hasta el modelado de amenazas, análisis, explotación controlada, post-explotación e informe.

OWASP Web Security Testing Guide (WSTG). Proporciona escenarios de prueba especializados para aplicaciones web: información, configuración, identidad, autenticación, autorización, sesiones, validación de entradas, errores, criptografía, lógica de negocio y cliente web.

Metodología propuesta

Se utilizará PTES como marco de gobierno del proyecto y OWASP WSTG como guía técnica de pruebas web. La combinación es adecuada porque Aurora Market requiere una evaluación autorizada, con alcance y comunicación formal, pero el activo central es una aplicación de comercio electrónico. PTES asegura que el ejercicio sea controlado y documentado; WSTG mejora la cobertura técnica y la repetibilidad.

Aplicación al caso

- Priorizar autenticación, sesiones, autorización, exposición de datos y lógica de carrito/compra por su relación con información personal y operaciones comerciales.
- Usar una matriz de pruebas con identificador, objetivo, resultado, evidencia y severidad, manteniendo datos de prueba en todo momento.
- Clasificar hallazgos por impacto y probabilidad, comunicar de inmediato los críticos y validar las correcciones mediante reprobación.

Conclusión

El pentest Gray Box permitirá a Aurora Market conocer su riesgo real antes de la campaña sin comprometer la continuidad del negocio ni la privacidad de sus clientes. El éxito se medirá por la claridad de los hallazgos, la utilidad de las recomendaciones y la corrección verificable de los riesgos, no por la cantidad de ataques ejecutados.

Referencias

OWASP Foundation. Web Security Testing Guide. <https://owasp.org/www-project-web-security-testing-guide/>

PTES. Penetration Testing Execution Standard. <http://www.pentest-standard.org/>

OWASP Foundation. Application Security Verification Standard.

<https://owasp.org/www-project-application-security-verification-standard/>